Планировщик отпусков

КОРПОРАТИВНЫЙ ГРАФИК ОТПУСКОВ И СОГЛАСОВАНИЙ

Спецификация API v1

Протокол, ошибки, права доступа · версия 0.6.0

29 октября 2026

© Alexander Yurasov

Содержание

1 О документе 3

2 Термины 4

3 Общие правила протокола 6

4 Аутентификация 7

5 Жизненный цикл заявки 10

6 Согласование: замещение и эскалация 12

7 Извещения о начале отпуска 13

8 Планирование и график отпусков 14

9 Аналитика и подбор дат 15

10 Импорт сотрудников 16

11 Списки для руководителя 17

12 Письма 18

13 Живые обновления 19

14 Каталог операций 20

15 Каталог ошибок 30

16 Матрица прав 32

17 Версионирование и совместимость 34

18 Чек-лист новой операции 35

1 О документе

Документ задаёт протокол взаимодействия клиента и сервера «Планировщика отпусков»: общие правила, аутентификацию, семантику операций, права доступа, каталог ошибок и правила совместимости. Формальный контракт — `contracts/openapi-vacation-api-v1.yaml` (OpenAPI 3.1). Документ дополняет его тем, что нельзя выразить схемой: права, переходы состояний, побочные эффекты.

Главное правило: сервер не доверяет клиенту. Любое ограничение, которое клиент проверяет для удобства, сервер проверяет повторно как обязательное.

Соответствие контракта и реализации проверяет тест `server/test/contract.e2e.test.ts`: каждый маршрут сервера описан в контракте, и каждая операция контракта реализована. Каталоги операций и ошибок ниже сформированы из контракта и кода (`tools/docs/gen_tables.py`).

2 Термины

ТЕРМИН	ЗНАЧЕНИЕ
Автор	Сотрудник, на которого оформлена заявка
Согласующий	Непосредственный руководитель автора (поле `managerId`), у автора без руководителя — руководитель отдела; руководитель отдела вправе решать по любому сотруднику отдела; администратор — по любой заявке. По своей заявке не решает никто, кроме администратора
Заместитель	Сотрудник, которому руководитель передал согласование на период (`/delegations`): на этот период у него права согласующего по команде руководителя
Эскалация	Передача заявки без решения дольше `escalationDays` дней руководителю согласующего (`escalatedTo`); без него — уведомление кадровой службе
Сеанс	Цепочка refresh-токенов одного входа; в access-токене — `sid`
Извещение	Извещение о начале отпуска под подпись не позднее чем за две недели (ТК РФ, ст. 123)
Кампания планирования	Сбор планов отпусков на год со сроком; утверждённый график — снимок согласованных отпусков с реквизитами документа, основа формы Т-7
Кадровая служба	Сотрудник с признаком `isHr`: ведёт сотрудников, импорт, оргструктуру и календарь, видит выгрузки, аналитику и аудит всей организации
Норма	`plannedDays + carryOver` — дни отпуска на год с учётом переноса
Дни отпуска	Календарные дни периода без нерабочих праздничных (ТК РФ ст. 120)
Доступно	Норма − согласованные дни − дни на согласовании
Перенос	Изменение дат согласованного отпуска; прежние даты хранятся в `changeFrom` до решения

ТЕРМИН	ЗНАЧЕНИЕ
Запрос удаления	Согласованный отпуск с `pendingDeletion = true`, ожидающий решения руководителя
Порог конфликта	Доля отдела в отпуске (настройка организации, по умолчанию 50 %), начиная с которой день конфликтный

3 Общие правила протокола

1. Базовый префикс `/api/v1`, тело — JSON, кодировка UTF-8; даты — `YYYY-MM-DD`, метки времени — RFC 3339 в UTC.
2. Аутентификация — заголовок `Authorization: Bearer <access JWT>`; refresh-токен передаётся только httpOnly-cookie `vp_refresh`.
3. Пагинация списков: `page` (с 1) и `per_page` (1–200, по умолчанию 50); ответ `{ items, meta: { page, perPage, total } }`.
4. Частичное изменение — `PATCH` только с изменяемыми полями. Неизвестные поля запроса отбрасываются, клиент обязан игнорировать неизвестные поля ответа.
5. Повторное решение по заявке не дублирует эффект: если заявка уже не на согласовании, сервер отвечает `409 stale-state`, клиент перечитывает данные.
6. Тяжёлые чтения ограничены: график — не длиннее 370 дней, график работы и подбор дат — не длиннее 400 дней.
7. Ограничение частоты входа: 10 попыток в минуту на пару «адрес + логин» и 60 на адрес → `429 rate-limited` с заголовком `Retry-After` (секунд). Счётчики общие для всех процессов и экземпляров сервера.
8. Ошибки — только `application/problem+json` (RFC 9457) с кодом из каталога ниже.
9. Перегрузка или недоступность БД — `503 service-unavailable` с заголовком `Retry-After`; любую операцию чтения клиент может повторить по истечении паузы.
10. `GET /schedule` отдаёт слабый `ETag` по версии данных и `Cache-Control: private, no-cache`. Запрос с `If-None-Match`, равным текущему `ETag`, получает `304 Not Modified` без тела. Версия меняется при любом изменении заявок, сотрудников, отделов, проектов, графиков работы и правил организации.
11. Пароль, выданный кадровой службой (создание, импорт, сброс), — одноразовый: пока он не сменён, любая операция, кроме смены пароля, профиля, политики паролей и выхода, отвечает `403 auth/password-change-required`.
12. Завершённый сеанс (выход, завершение со списка сеансов, кадровой службой, повтор refresh-токена) отзывает выданные access-токены: `401 auth/token-expired` не позже чем через 10 секунд.

4 Аутентификация

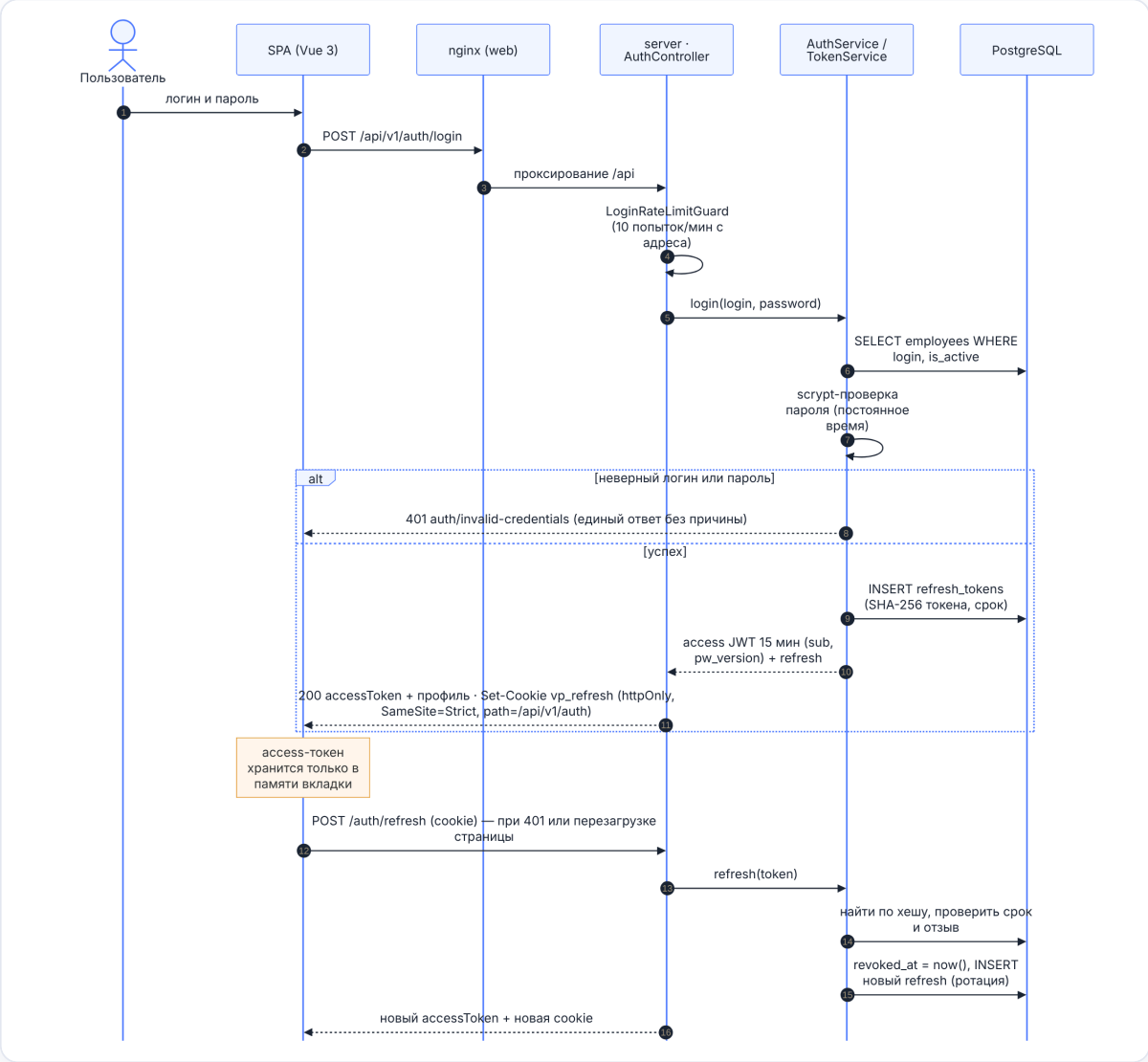


Рис. 1. Вход и продление сессии

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`POST /auth/login`	Логин и пароль → `accessToken` (15 минут) и профиль; refresh-cookie на 30 дней (`HttpOnly` , `SameSite=Strict` , `Secure` в production, `Path=/api/v1/auth`). Начинает сеанс; учётная запись заблокирована — `423 auth/account-locked` (только при верном пароле)

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`POST /auth/refresh`	По cookie выдаёт новый access-токен и новую cookie в том же сеансе; использованный refresh-токен отзывается атомарно. Повтор того же токена в течение 30 секунд (параллельная вкладка) — пара того же сеанса; позже — сеанс завершается целиком, `401`
`POST /auth/logout`	Завершает текущий сеанс и удаляет cookie
`GET /auth/me`	Профиль и вычисленные права: подчинённые, администратор, `approvals` — есть ли что согласовывать (команда, замещение, эскалированные заявки); `employee.mustChangePassword`
`POST /auth/password`	Смена своего пароля по старому по политике паролей; все сеансы завершаются
`GET /auth/password-policy`	Минимальная длина и правила — для подсказки на экранах смены пароля (без входа)
`GET /auth/sessions`	Свои сеансы: способ входа, начало, последнее обновление, адрес, браузер; `current` — сеанс запроса
`DELETE /auth/sessions/{id}`, `POST /auth/sessions/revoke-others`	Завершить сеанс или все, кроме текущего
`PATCH /auth/me`	Личные настройки: `emailNotifications` — письма о заявках и сводка
`GET /auth/oidc/config`	Включён ли единый вход, подпись кнопки, разрешён ли вход по паролю
`GET /auth/oidc/start` → `GET /auth/oidc/callback`	Единый вход OpenID Connect: authorization code + PKCE; успех — refresh-cookie и переход в приложение, отказ — `/login?sso=cancelled|expired|invalid|unknown`

Безопасность входа (с v0.6.0). Неудачные попытки подряд считаются по учётной записи; после `lockoutThreshold` (правило организации, по умолчанию 10; 0 — без блокировки) вход блокируется на `lockoutMinutes` (по умолчанию 15), сотрудник получает уведомление. Пароль проверяется по политике (`400 validation/weak-password`): длина не меньше `passwordMinLength`, без логина и фамилии, не из распространённых, не последовательность, не текущий. Каждая попытка входа и повтор refresh-токена пишутся в журнал входов (`GET /login-events`, кадровая служба). Кадровая служба видит состояние учётной записи (`GET /employees/{id}/security`),

снимает блокировку (`POST /employees/{id}/unlock`), завершает сеансы (`POST /employees/{id}/sessions/revoke`) и выдаёт новый одноразовый пароль (`POST /employees/{id}/password-reset`).

Смена пароля и увольнение сотрудника отзывают все выданные токены: следующий запрос со старым access-токеном получает `401 auth/token-expired` (в других процессах сервера — не позже чем через 10 секунд), refresh-токены отзываются сразу. `auth/token-expired` клиент обрабатывает как истёкший сеанс: пробует `refresh` , при неудаче — экран входа.

При `LOCAL_LOGIN=false` вход по паролю сотрудникам запрещён (`403 auth/forbidden`), администраторам он остаётся как аварийный.

Неверный логин или пароль — единый ответ `401 auth/invalid-credentials` , который не раскрывает, что именно неверно. Клиент при `401` один раз вызывает `refresh` (общий для всех параллельных запросов) и повторяет запрос; при неудаче — переход на экран входа.

5 Жизненный цикл заявки

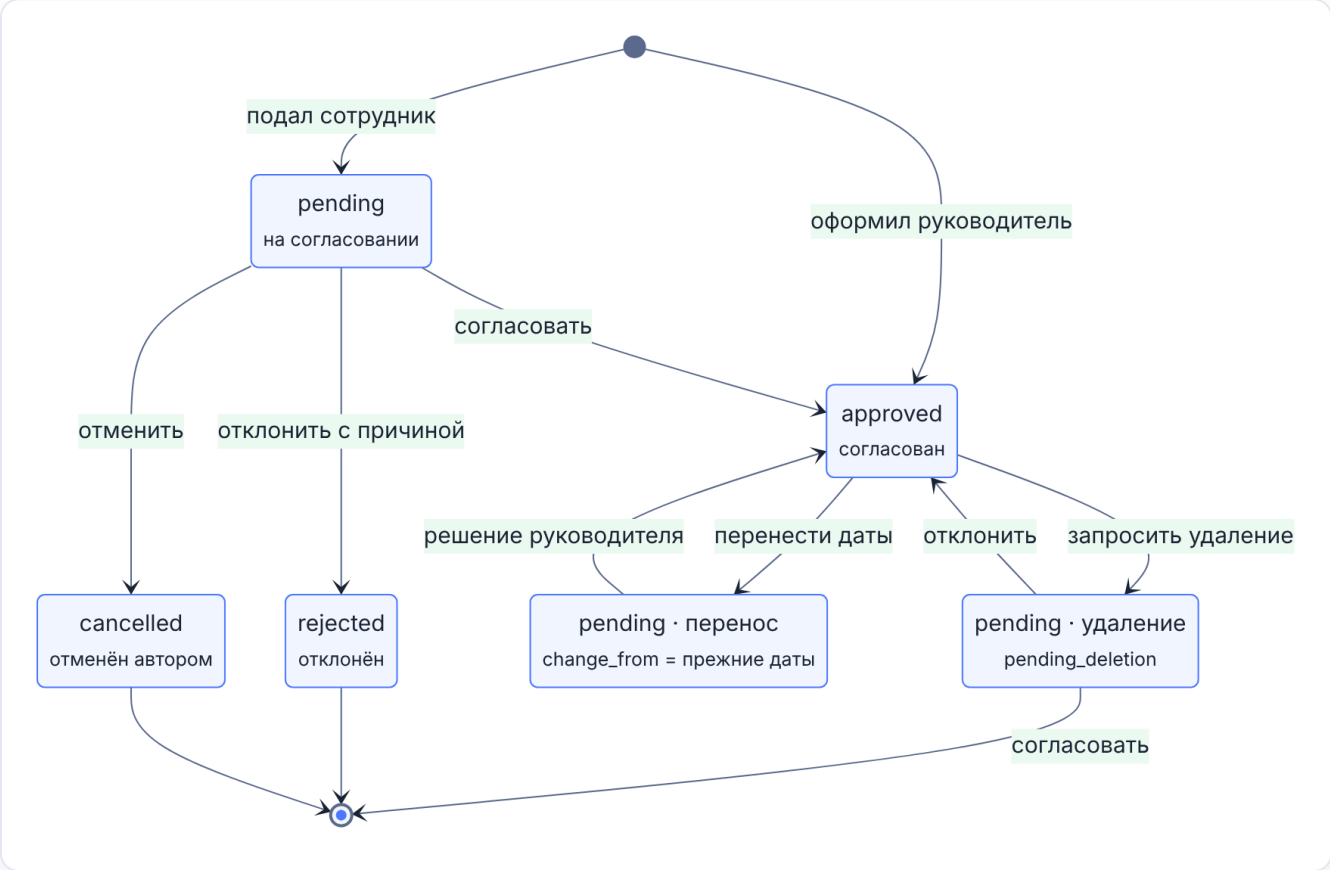


Рис. 2. Состояния заявки

1. `POST /vacation-requests` создаёт заявку `pending`. Если её оформляет руководитель за подчинённого или администратор — сразу `approved`. Сервер проверяет права, формат и порядок дат, «не в прошлом» (кроме администратора), пересечения с заявками сотрудника (`409 overlapping-request`) и лимит дней при жёсткой политике (`409 limit-exceeded`).
2. Автор правит даты `pending`-заявки через `PATCH`. Для `approved` тот же `PATCH` создаёт перенос: заявка переходит в `pending`, прежние даты сохраняются в `changeFrom`.
3. `DELETE` отменяет `pending`-заявку (`cancelled`) или запрашивает удаление `approved` (`pending` + `pendingDeletion`).
4. Согласующий вызывает `POST …/approve`: новая заявка и перенос становятся `approved`, запрос удаления удаляет заявку (событие остаётся в истории и аудите).
5. `POST …/reject` с обязательной причиной (3–1000 символов): новая заявка — `rejected`; перенос — возврат к прежним датам и `approved`; запрос удаления — отпуск остаётся `approved`.
6. Каждый переход пишет событие в историю заявки, запись `audit_events` и уведомление — в одной транзакции.

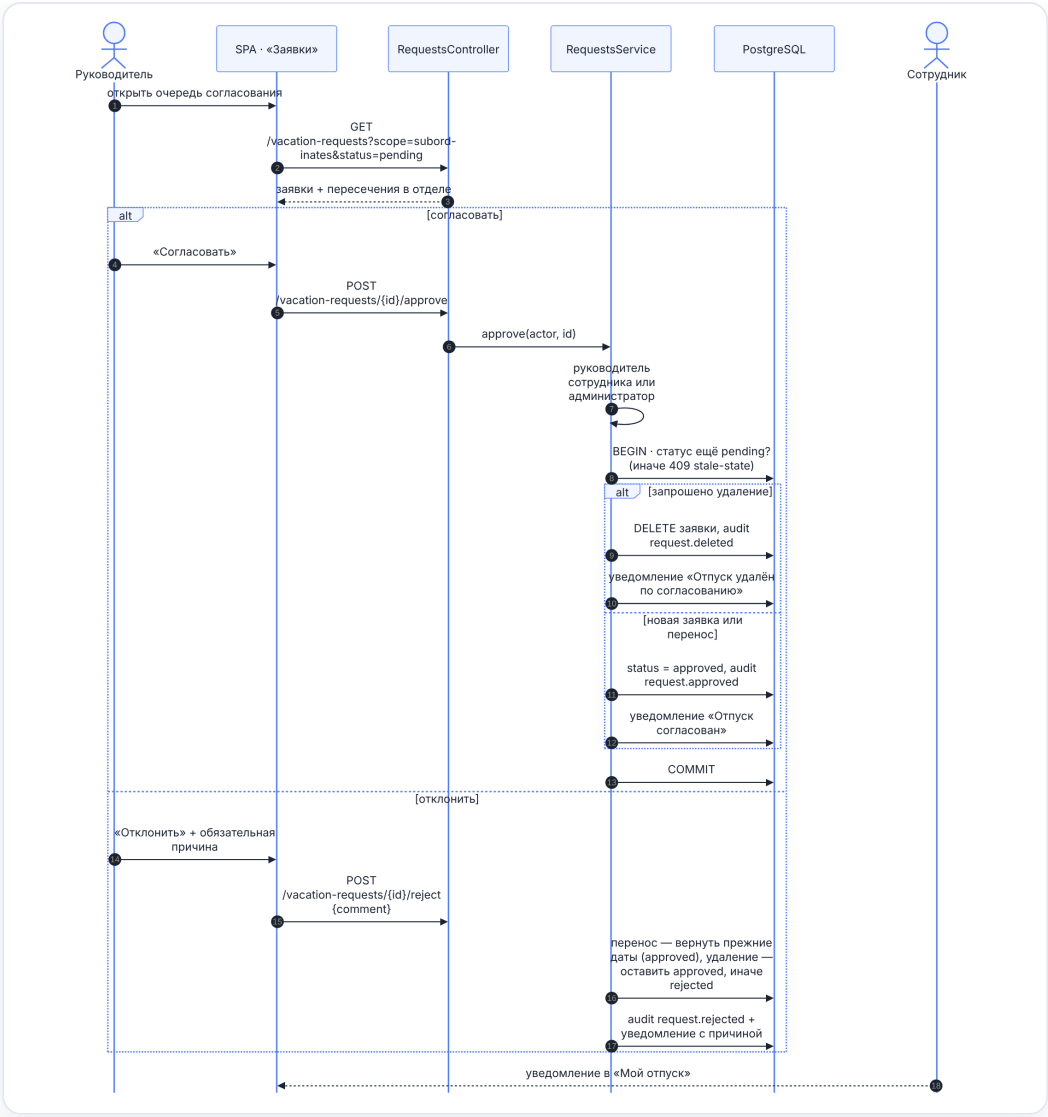


Рис. 3. Решение руководителя

6 Согласование: замещение и эскалация

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`GET /vacation-requests?scope=approvals`	«Ждут моего решения»: заявки подчинённых и сотрудников руководимого отдела без руководителя, команды руководителей, которых я замещаю сегодня, и переданные мне эскалацией; своих нет. Элементы несут `pendingSince`, `escalatedTo`, `escalatedAt`
`POST /delegations`	Руководитель передаёт согласование заместителю на период (`managerId` — за руководителя, только кадровая служба). Даты не в прошлом, не дольше года, заместитель работает и не сам руководитель, у руководителя есть команда, одно замещение на любой день. Заместитель получает уведомление `delegation_assigned`, назначение — в аудите
`GET /delegations`, `DELETE /delegations/{id}`	Переданные и полученные замещения; отмена — руководитель или кадровая служба

Заявка без решения дольше `escalationDays` дней (правило организации, 0 — выключено) передаётся руководителю согласующего: он получает право решения и уведомление `request_escalated`; если выше никого нет — кадровая служба получает `request_stalled`. Заявка передаётся один раз; отметка остаётся после решения и сбрасывается переносом или запросом удаления.

7 Извещения о начале отпуска

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
Плановая задача	За `noticeDays` (14–60, по умолчанию 14) дней до начала согласованного ежегодного отпуска штатного сотрудника — извещение, уведомление `vacation_notice` и письмо. Отпуск, согласованный позже, — извещение сразу с `late = true` и указанием на ст. 124. Одно извещение на заявку и дату начала
`GET /notices/mine`	Свои действующие извещения: предстоящие и за последние 90 дней
`POST /notices/{id}/acknowledge`	«Ознакомлен» — только сам сотрудник; повтор ничего не меняет; отозванное — `400`; в аудите `notice.acknowledged`
`GET /notices/{id}`	Извещение для печати под подпись: своё или любое для кадровой службы
`GET /notices?from&to&status&dept`	Журнал кадровой службы по дате начала отпуска; `overdue` — не подтверждено, а до начала 3 дня и меньше; `unacknowledged` — сколько не подтверждено
`GET /reports/notices?from&to`	Журнал за период в XLSX

Перенос на новые даты, отмена отпуска и увольнение отзывают извещение (`withdrawnAt`), отклонённый перенос возвращает его в силу.

8 Планирование и график отпусков

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`POST /planning/{year}/open`	Открыть планирование текущего или следующего года со сроком (или изменить срок, или открыть снова после закрытия); открытие приглашает всех штатных сотрудников (`planning_open`)
`GET /planning/{year}` , `GET /planning/{year}/employees`	Кампания, утверждение, прогресс по отделам и сотрудникам: запланировали, полностью (норма и часть не короче 14 дней), дней из нормы; предупреждения перед утверждением
`POST /planning/{year}/remind`	Напоминание `planning_reminder` тем, кто не спланировал полностью, — с их цифрами; не чаще раза в час. Автоматически — один раз за 3 дня до срока
`POST /planning/{year}/close`	Закрыть планирование
`POST /planning/{year}/approve`	Утвердить график: номер и дата документа, мнение профсоюза; один раз, до начала года, хотя бы один согласованный отпуск. Снимок согласованных отпусков года; кампания закрывается
`GET /reports/t7?year`	Форма Т-7 (ОКУД 0301020) в XLSX: утверждённый график с переносами в графах 8–9 или проект до утверждения
`GET /planning/mine`	Сотруднику — открытая кампания и свой прогресс

Отпуск относится к году по дате начала. В прогресс входят согласованные отпуска и заявки на согласовании, в утверждённый график — только согласованные.

9 Аналитика и подбор дат

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`GET /analytics/departments`	Отделы, доступные пользователю: администратору — все; руководителю — отделы, где работают его подчинённые или которыми он руководит; сотруднику — свой
`GET /analytics/overview?dept&year`	Доля отдела в отпуске по месяцам (только рабочие дни; отдельно с учётом заявок на согласовании), периоды конфликтов с составом, распределение дней по сотрудникам, выводы с уровнем важности
`GET /analytics/team?dept|project&date`	Состав на дату: офис, удалёнка, отпуск (с датой окончания), выходной; следующий отпуск, нераспределённые дни, часть в 14 дней, заявки на согласовании
`GET /analytics/suggestions?days&from&to&employee`	До пяти непересекающихся окон для отпуска заданной длины с оценкой и объяснением; праздники продлевают окно, окна с превышением порога и пересечением с собственными отпусками исключаются

Подбор дат доступен для себя, руководителю — для прямых подчинённых, администратору — для любого сотрудника. Статус «офис / удалёнка» вычисляется так: отпуск важнее всего, затем разовое исключение, затем выходной или праздник, затем недельный шаблон (по умолчанию — офис).

10 Импорт сотрудников

`POST /imports/employees?dryRun=true|false` принимает файл XLSX/CSV (multipart, поле `file`, до 2 МБ, до 5000 строк) или JSON `{ rows }` — точку синхронизации с кадровой системой. Колонки: ФИО (обязательно), Логин, Должность, Отдел, Руководитель (логин или ФИО), Норма дней, Перенос, Тип занятости, Email, Табельный номер (уникален в организации, с v0.6.0); шаблон — `GET /imports/employees/template`.

ПРАВИЛО	ПОВЕДЕНИЕ
Сопоставление	По логину; без логина — по ФИО среди работающих (несколько совпадений — ошибка строки)
Новый сотрудник	Логин транслитом ФИО с числовым суффиксом при совпадении; одноразовый пароль — в ответе применения один раз
Пустая ячейка	Значение не меняется; повторная загрузка того же файла ничего не меняет
Новые отделы	Создаются; руководитель может быть создан этим же файлом
Ошибки	По строкам в плане; `dryRun=false` при ошибках отклоняется целиком (`400`)
Права	Кадровая служба и администратор; кадровая служба не меняет администраторов и коллег по службе

11 Списки для руководителя

ОПЕРАЦИЯ	ПОВЕДЕНИЕ
`GET /employees?manager={id}`	Только прямые подчинённые сотрудника `id` (с v0.5.0). Экран согласования и график работы руководителя берут подчинённых так, а не перебором первых 200 сотрудников организации
`GET /vacation-requests`	Элементы списка несут `employeeName` и `employeeDept` (с v0.5.0): очередь согласования запрашивает график только отделов из очереди, чтобы показать пересечения
`POST /notifications/read-all`	Отмечает прочитанными все уведомления текущего сотрудника одним запросом, ответ `{ marked }` (с v0.5.0)

Норма дней и перенос в карточке сотрудника (`POST` / `PATCH /employees`) — числа с точностью до сотых, от 0 до 365, как в импорте; до v0.5.0 API принимал только целые, и правка карточки округляла перенос из импорта.

12 Письма

Письма отправляются, если на сервере задан `SMTP_HOST`. Письмо создаётся в той же транзакции, что уведомление (`email_outbox`), и уходит фоном с повторами; сбой почты не влияет на операцию. Руководитель (и его заместитель) получает письмо о новой заявке, переносе и запросе удаления, сотрудник — о решении. С v0.6.0 — также письма об эскалации и заявке без решения, о назначенном замещении, о блокировке учётной записи, извещение о начале отпуска и письма кампании планирования (приглашение и напоминание). В пятницу после 12:00 по времени организации руководители получают сводку: кто из команды в отпуске на следующей неделе и сколько заявок ждут решения. Отписка — `PATCH /auth/me`. Администратор проверяет SMTP операцией `POST /settings/test-email`.

13 Живые обновления

Клиент держит поток Server-Sent Events и перечитывает данные по сигналу вместо опроса по таймеру.

ШАГ	ПОВЕДЕНИЕ
`POST /events/ticket`	По access-токену выдаёт билет `{ ticket }` на 60 секунд. Билет — JWT с отдельной аудиторией: им нельзя вызвать другие операции
`GET /events?ticket=…`	Открывает поток `text/event-stream`. Билет недействителен, пароль сменён или сотрудник уволен — `401`
`event: hello`	Сразу после открытия: `{ unread, version }` — непрочитанные уведомления и версия данных
`event: notifications`	Новые уведомления сотрудника: `{ unread }`; клиент перечитывает уведомления и очередь заявок
`event: data`	Версия данных изменилась: `{ version }`; не чаще раза в 15 секунд. Клиент тихо перечитывает график на видимой вкладке
`event: revoked`	Сеанс отозван — пароль сменён или сброшен, сотрудник уволен: `{}`, затем сервер закрывает поток. Сервер сверяет подключённых раз в 10 секунд; клиент сразу переходит на экран входа с сообщением «Сеанс завершён»
Комментарий `:` раз в 25 секунд	Держит соединение через прокси; данных не несёт

Сервер проверяет события раз в 2 секунды. При обрыве клиент закрывает поток, получает новый билет и переподключается с нарастающей паузой от 4 до 60 секунд; пока потока нет, он опрашивает уведомления раз в 30 секунд, как до v0.5.0.

14 Каталог операций

Всего операций: **83** в 67 путях; формат — JSON, ошибки — `application/problem+json`.

Вход и сессии (13)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/auth/login`	Вход по логину и паролю	`login`
POST	`/api/v1/auth/refresh`	Новый access-токен по refresh-cookie (ротация; старый refresh отзывается)	`refresh`
POST	`/api/v1/auth/password`	Смена своего пароля (все сессии завершаются)	`changeOwnPassword`
GET	`/api/v1/auth/password-policy`	Требования к паролю — минимальная длина (для форм смены пароля)	`getPasswordPolicy`
GET	`/api/v1/auth/sessions`	Мои активные сеансы	`listMySessions`
DELETE	`/api/v1/auth/sessions/{id}`	Завершить свой сеанс (текущий — как выход)	`revokeMySession`
POST	`/api/v1/auth/sessions/revoke-others`	Завершить все свои сеансы, кроме текущего	`revokeOtherSessions`
POST	`/api/v1/auth/logout`	Завершить сессию	`logout`
GET	`/api/v1/auth/me`	Текущий пользователь и его права	`getMe`
PATCH	`/api/v1/auth/me`	Личные настройки — письма о заявках	`updateMyPreferences`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/auth/oidc/config`	Единый вход — включён ли, подпись кнопки, разрешён ли вход по паролю	`getSsoConfig`
GET	`/api/v1/auth/oidc/start`	Начать вход через провайдер OpenID Connect	`startSso`
GET	`/api/v1/auth/oidc/callback`	Возврат от провайдера	`ssoCallback`

Аудит (2)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/login-events`	Журнал входов (администратор, кадровая служба)	`listLoginEvents`
GET	`/api/v1/audit-events`	Журнал изменений (администратор)	`listAuditEvents`

Замещение (3)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/delegations`	Замещения: переданные мной и полученные мной (действующие и будущие)	`listDelegations`
POST	`/api/v1/delegations`	Передать согласование заместителю на период	`createDelegation`
DELETE	`/api/v1/delegations/{id}`	Отменить замещение (руководитель или кадровая служба)	`revokeDelegation`

Извещения (4)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/notices/mine`	Мои действующие извещения о начале отпуска (предстоящие и за последние 90 дней)	`listMyNotices`
GET	`/api/v1/notices`	Журнал извещений (кадровая служба, администратор)	`listNotices`
GET	`/api/v1/notices/{id}`	Извещение для печати под подпись (сотрудник — своё, кадровая служба — любое)	`getNotice`
POST	`/api/v1/notices/{id}/acknowledge`	Ознакомлен с извещением (только сам сотрудник)	`acknowledgeNotice`

Планирование и форма Т-7 (7)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/planning/mine`	Открытая кампания планирования и мой прогресс	`getMyPlanning`
GET	`/api/v1/planning/{year}`	Кампания, утверждение и прогресс по отделам (кадровая служба, администратор)	`getPlanning`
GET	`/api/v1/planning/{year}/employees`	Прогресс планирования по сотрудникам (кадровая служба)	`listPlanningEmployees`
POST	`/api/v1/planning/{year}/open`	Открыть планирование на год, открыть снова или изменить срок	`openPlanning`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/planning/{year}/close`	Закрыть планирование (planning.closed в аудите)	`closePlanning`
POST	`/api/v1/planning/{year}/remind`	Напомнить не спланировавшим отпуск	`remindPlanning`
POST	`/api/v1/planning/{year}/approve`	Утвердить график отпусков на год	`approveSchedule`

Сотрудники (10)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/employees`	Список сотрудников (постранично, с фильтрами)	`listEmployees`
POST	`/api/v1/employees`	Создать сотрудника (только администратор)	`createEmployee`
GET	`/api/v1/employees/{id}`	Карточка сотрудника	`getEmployee`
PATCH	`/api/v1/employees/{id}`	Изменить поля сотрудника	`updateEmployee`
DELETE	`/api/v1/employees/{id}`	Уволить/ удалить сотрудника (только администратор)	`deleteEmployee`
PUT	`/api/v1/employees/{id}/password`	Смена пароля (свой — со старым; чужой — кадровая служба, пароль одноразовый)	`changePassword`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/employees/{id}/password-reset`	Сброс пароля — сервер выдаёт одноразовый пароль (кадровая служба)	`resetPassword`
GET	`/api/v1/employees/{id}/security`	Учётная запись: последний вход, блокировка, одноразовый пароль, сеансы (кадровая служба)	`getEmployeeSecurity`
POST	`/api/v1/employees/{id}/unlock`	Снять блокировку после неудачных попыток входа (кадровая служба)	`unlockEmployee`
POST	`/api/v1/employees/{id}/sessions/revoke`	Завершить все сеансы сотрудника (кадровая служба)	`revokeEmployeeSessions`

Баланс (1)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/employees/{id}/balance`	Баланс дней отпуска за год	`getBalance`

График и режим работы (5)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
PUT	`/api/v1/employees/{id}/work-pattern`	Недельный шаблон офис/удалёнка (свой или подчинённый)	`setWorkPattern`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
PUT	`/api/v1/employees/{id}/work-overrides`	Ручное переопределение режима на дату	`setWorkOverride`
GET	`/api/v1/employees/{id}/work-schedule`	График работы — недельный шаблон и исключения за период (с v0.3.0)	`getWorkSchedule`
DELETE	`/api/v1/employees/{id}/work-overrides/{date}`	Снять исключение — на дату снова действует недельный шаблон (с v0.3.0)	`deleteWorkOverride`
GET	`/api/v1/schedule`	График отпусков и режимов за период	`getSchedule`

Заявки на отпуск (7)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/vacation-requests`	Заявки (свои, подчинённых или все — по правам)	`listVacationRequests`
POST	`/api/v1/vacation-requests`	Создать заявку (за себя или за подчинённого)	`createVacationRequest`
GET	`/api/v1/vacation-requests/{id}`	Заявка с историей	`getVacationRequest`
PATCH	`/api/v1/vacation-requests/{id}`	Изменить свою pending-заявку или запросить перенос approved	`updateVacationRequest`
DELETE	`/api/v1/vacation-requests/{id}`	Отменить свою pending-заявку или запросить удаление approved	`cancelVacationRequest`
POST	`/api/v1/vacation-requests/{id}/approve`	Согласовать (руководитель сотрудника или администратор)	`approveVacationRequest`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/vacation-requests/{id}/reject`	Отклонить с обязательным комментарием	`rejectVacationRequest`

Справочники (12)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/departments`	Отделы с руководителями и численностью	`listDepartments`
POST	`/api/v1/departments`	Создать отдел (администратор)	`createDepartment`
PATCH	`/api/v1/departments/{name}`	Переименовать, сменить руководителя	`updateDepartment`
DELETE	`/api/v1/departments/{name}`	Удалить отдел (нельзя при наличии сотрудников)	`deleteDepartment`
GET	`/api/v1/projects`	Проекты	`listProjects`
POST	`/api/v1/projects`	Создать проект (администратор)	`createProject`
PATCH	`/api/v1/projects/{id}`	Изменить проект	`updateProject`
DELETE	`/api/v1/projects/{id}`	Удалить проект (нельзя при наличии участников)	`deleteProject`
GET	`/api/v1/groups`	Пользовательские группы для фильтров	`listGroups`
POST	`/api/v1/groups`	Создать группу	`createGroup`
PATCH	`/api/v1/groups/{id}`	Изменить название или состав	`updateGroup`
DELETE	`/api/v1/groups/{id}`	Удалить группу	`deleteGroup`

Настройки (3)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/settings`	Настройки организации	`getSettings`
PATCH	`/api/v1/settings`	Изменить настройки (только администратор)	`updateSettings`
POST	`/api/v1/settings/test-email`	Проверочное письмо администратору (проверка SMTP после развёртывания)	`sendTestEmail`

Производственный календарь (2)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/calendar/holidays/{year}`	Праздники и переносы производственного календаря	`getHolidays`
PUT	`/api/v1/calendar/holidays/{year}`	Загрузить или изменить календарь года (кадровая служба, администратор)	`setHolidays`

Уведомления (3)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/notifications`	Уведомления текущего пользователя	`listNotifications`
POST	`/api/v1/notifications/read-all`	Пометить прочитанными все уведомления (с v0.5.0)	`markAllNotificationsRead`
POST	`/api/v1/notifications/{id}/read`	Пометить прочитанным	`markNotificationRead`

imports (2)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/imports/employees`	Импорт сотрудников и остатков — предпросмотр или применение	`importEmployees`
GET	`/api/v1/imports/employees/template`	Шаблон XLSX для импорта сотрудников	`getImportTemplate`

events (2)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
POST	`/api/v1/events/ticket`	Билет на поток событий (60 секунд)	`getEventsTicket`
GET	`/api/v1/events`	Поток событий (text/event-stream)	`streamEvents`

Отчёты (3)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/reports/vacations`	Выгрузка отпусков за период (XLSX)	`exportVacations`
GET	`/api/v1/reports/t7`	График отпусков по унифицированной форме Т-7 (XLSX; кадровая служба)	`exportT7`
GET	`/api/v1/reports/notices`	Журнал извещений за период (XLSX; кадровая служба, администратор)	`exportNotices`

Аналитика (4)

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/analytics/departments`	Отделы, доступные пользователю для аналитики (с v0.3.0)	`listAnalyticsDepartments`

МЕТОД	ПУТЬ	НАЗНАЧЕНИЕ	ОПЕРАЦИЯ
GET	`/api/v1/analytics/overview`	Нагрузка отдела по месяцам, периоды конфликтов, распределение дней, выводы (с v0.3.0)	`getDepartmentOverview`
GET	`/api/v1/analytics/team`	Состав отдела или проекта на дату — офис, удалёнка, отпуск, выходной (с v0.3.0)	`getTeamToday`
GET	`/api/v1/analytics/suggestions`	Лучшие окна для отпуска с учётом нагрузки отдела и праздников (с v0.3.0)	`suggestVacationDates`

15 Каталог ошибок

`type` — `https://vacation.planner/problems/<код>`; `title` — короткий текст для человека, `detail` — уточнение для конкретного случая. Новые коды добавляются одновременно в `server/src/infra/problems.ts`, контракт и документ 5 (тексты интерфейса).

КОД (TYPE)	HTTP	ЗАГОЛОВОК (TITLE)
`auth/invalid-credentials`	401	Неверный логин или пароль
`auth/token-expired`	401	Сессия истекла
`auth/forbidden`	403	Недостаточно прав для этого действия
`auth/account-locked`	423	Учётная запись временно заблокирована после неудачных попыток входа
`auth/password-change-required`	403	Смените пароль, выданный администратором
`validation/invalid-field`	400	Некорректно заполнено поле
`validation/weak-password`	400	Пароль не соответствует политике паролей
`validation/bad-date-range`	400	Дата окончания раньше даты начала или даты в прошлом
`not-found`	404	Запись не существует или удалена
`overlapping-request`	409	Период пересекается с существующей заявкой
`limit-exceeded`	409	Превышен остаток дней отпуска
`stale-state`	409	Данные изменились: обновите страницу и повторите
`last-admin`	409	Нельзя удалить или разжаловать последнего администратора
`department-not-empty`	409	В отделе ещё есть сотрудники
`rate-limited`	429	Слишком много запросов. Повторите позже.

КОД (TYPE)	HTTP	ЗАГОЛОВОК (TITLE)
`calendar-missing`	400	Для этого года не загружен производственный календарь
`service-unavailable`	503	Сервис перегружен. Повторите через несколько секунд.

16 Матрица прав

ДЕЙСТВИЕ	СОТРУДНИК	РУКОВОДИТЕЛЬ	КАДРОВАЯ СЛУЖБА	АДМИНИСТРАТОР
Смотреть график организации	да	да	да	да
Подавать, переносить, отменять свои заявки	да	да	да	да
Оформлять отпуск за другого (сразу согласован)	—	прямым подчинённым	—	любому
Согласовывать и отклонять	—	заявки прямых подчинённых и сотрудников своего отдела без руководителя; заместителю — команды замещаемого; вышестоящему — эскалированные	—	все заявки
Передавать согласование заместителю	—	своё	за любого руководителя	за любого руководителя
Видеть баланс и график работы	свои	свои и подчинённых	любые	любые
Менять график работы	свой	свой и подчинённых	свой	любой
Команда и аналитика	свой отдел	свои отделы	все отделы	все отделы
Подбор дат	для себя	для себя и подчинённых	для любого	для любого
Выгрузка XLSX	—	свой отдел, если руководит им, иначе подчинённые	организация	организация

ДЕЙСТВИЕ	СОТРУДНИК	РУКОВОДИТЕЛЬ	КАДРОВАЯ СЛУЖБА	АДМИНИСТРАТОР
Сотрудники, импорт, сброс паролей	—	—	кроме администраторов и коллег по службе	да
Оргструктура, производственный календарь	—	—	да	да
Журнал аудита и журнал входов	—	—	да	да
Свои сеансы; ознакомление со своим извещением	да	да	да	да
Блокировка, сеансы и сброс пароля сотрудника	—	—	кроме администраторов и коллег по службе	да
Кампания планирования, утверждение графика, форма Т-7	—	—	да	да
Журнал извещений и его выгрузка	—	—	да	да
Правила организации, проверочное письмо	—	—	—	да
Выдача ролей «администратор» и «кадровая служба»	—	—	—	да

Права руководителя и кадровой службы складываются: руководитель отдела кадров согласует заявки своих подчинённых.

17 Версионирование и совместимость

1. Версия API — в префиксе пути. Несовместимое изменение — новый префикс `/api/v2`, обе версии работают не меньше 6 месяцев.
2. Добавляющие изменения (новые операции, необязательные поля, значения перечислений в конце) делаются в рамках v1 и отмечаются в описании операции «с vX.Y.Z».
3. Изменения `contracts/` проходят ревью владельца (CODEOWNERS); дифф контракта обязателен в описании PR.
4. Тест сверки контракта с реализацией входит в CI и блокирует слияние при расхождении.

18 Чек-лист новой операции

- Операция описана в контракте: `operationId`, параметры, схемы ответа, коды ошибок.
- DTO с class-validator: границы длин и чисел, форматы дат.
- Права проверены: роль — guard, объект — сервис.
- Ошибки — только из каталога.
- Изменение данных, история, аудит и уведомления — в одной транзакции.
- Тесты: успех, каждая ошибка, отказ в правах; для списков — пагинация.
- Обновлены тексты интерфейса (документ 5), CHANGELOG и таблицы документов (`tools/docs/gen_tables.py`).